

VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

Target Application	Zero Bank – http://zero.webappsecurity.com/
Date of Testing	31 May 2026
Report Date	31 May 2026
Prepared By	Sulav Adhikari
Designation	VAPT Intern
Organization	Arrownex Pvt Ltd

Table of Contents

Table of Contents.....	1
1. Executive Summary	2
1.1 Overview	2
1.2 Overall Security Posture	2
1.3 Risk Distribution.....	2
2. Scope & Methodology	2
2.1 Scope	2
2.2 Testing Restrictions	3
2.3 Tools Used	3
2.4 Methodology.....	3
3. Detailed Findings	3
3.1 Security Misconfiguration – Unprotected Admin Panel.....	4
Description.....	4
Impact.....	4
Proof of Concept.....	4
Recommendation.....	5
3.2 Vulnerable and Outdated Components.....	6
Description.....	6
Impact.....	6
Proof of Concept.....	6
Recommendation.....	7
4. Conclusion & Next Steps.....	7
4.1 Conclusion.....	7
4.2 Suggested Remediation Timeline	7
4.3 Next Steps.....	7

1. Executive Summary

1.1 Overview

A Vulnerability Assessment and Penetration Test (VAPT) was conducted on the Zero Bank web application (<http://zero.webappsecurity.com/>) to identify and evaluate security weaknesses that may impact the confidentiality, integrity, and availability of the system. Testing was performed following OWASP Top 10 guidelines and standard web application penetration testing practices.

During the assessment, two vulnerabilities were identified: an unprotected administrative panel discovered through directory enumeration, and the use of vulnerable and outdated server components identified through port scanning.

1.2 Overall Security Posture

Overall Posture	AT RISK
------------------------	----------------

1.3 Risk Distribution

Severity	Count
Critical	1
High	0
Medium	1
Low	0

2. Scope & Methodology

2.1 Scope

Field	Details
Target URL	http://zero.webappsecurity.com/
Application Type	Web Banking Application
Date of Testing	31 May 2026
Testing Type	Black-Box Penetration Testing
Excluded Areas	DoS attacks, brute force, third-party integrations

2.2 Testing Restrictions

- Active exploitation was performed in a safe and controlled manner.
- No destructive testing, denial-of-service attacks, or service disruption activities were conducted.
- All testing was performed on the authorized test environment only.

2.3 Tools Used

Tool	Purpose
Nmap 7.98	Port scanning, service/version detection, banner grabbing
DIRB v2.22	Web directory and file brute-force enumeration
Web Browser (Firefox)	Manual inspection of discovered endpoints
Kali Linux	Testing platform / operating system

2.4 Methodology

Testing was performed following the OWASP Top 10 (2021) guidelines and PTES methodology:

- Phase 1 – Reconnaissance: Active information gathering using DIRB for directory enumeration and Nmap for port and service scanning.
- Phase 2 – Vulnerability Identification: Manual review of discovered endpoints and analysis of detected server components.
- Phase 3 – Exploitation: Controlled proof-of-concept access to confirm vulnerability existence and assess impact.
- Phase 4 – Reporting: Documentation of all findings with screenshots, CVSS scores, and remediation guidance.

3. Detailed Findings

The following vulnerabilities were identified during the assessment:

SN	Finding	Severity	CVSS v3.1
3.1	Security Misconfiguration – Unprotected Admin Panel	Critical	9.1
3.2	Vulnerable and Outdated Components	Medium	6.5

3.1 Security Misconfiguration – Unprotected Admin Panel

Field	Details
OWASP Category	A05:2021 – Security Misconfiguration
CVSS v3.1 Score	9.1 – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Severity	CRITICAL
Affected URL / Component	http://zero.webappsecurity.com/admin/users.html

Description

The administrative panel is accessible without any authentication. Using DIRB directory enumeration, the /admin endpoint was discovered. Navigating to /admin/users.html exposes a full list of all registered users including their names, plaintext passwords, and Social Security Numbers (SSNs) to any unauthenticated visitor.

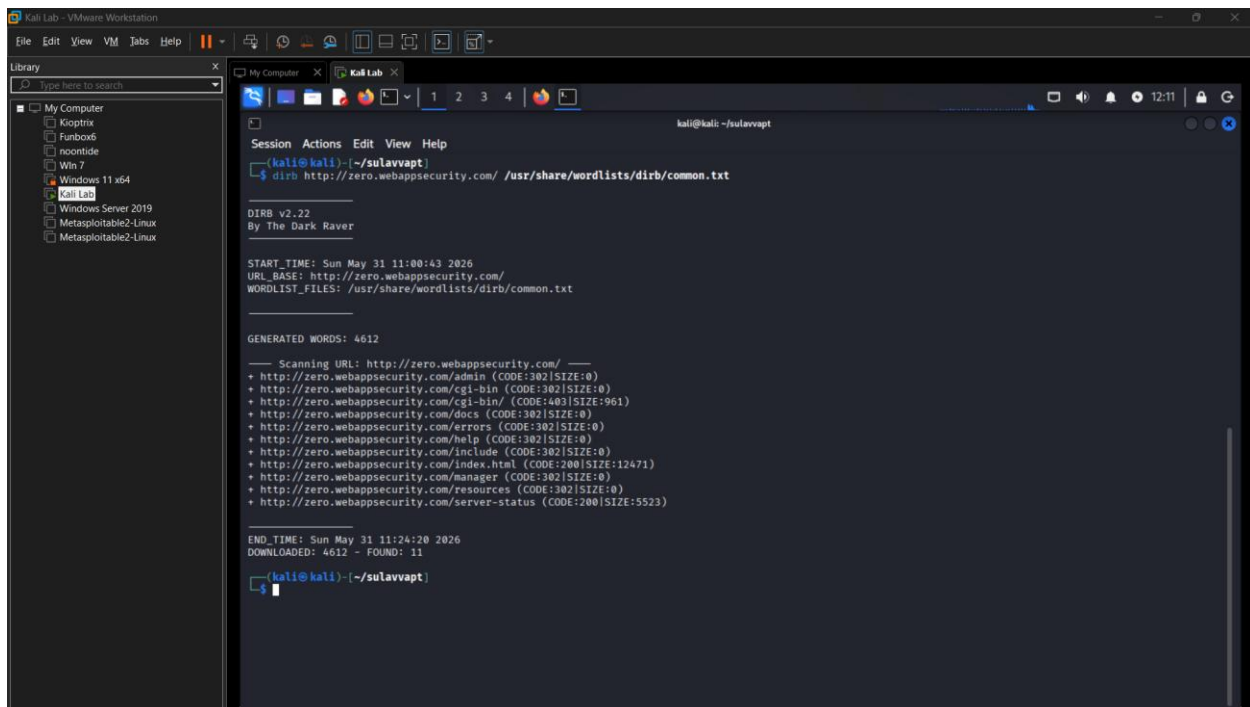
Impact

- Complete exposure of all user credentials (plaintext passwords) to any internet user.
- Full disclosure of PII – names and SSNs – violating GDPR and CCPA requirements.
- Passwords can be directly used to compromise user accounts or used in credential stuffing attacks.
- SSN exposure could lead to identity theft and significant legal liability.

Proof of Concept

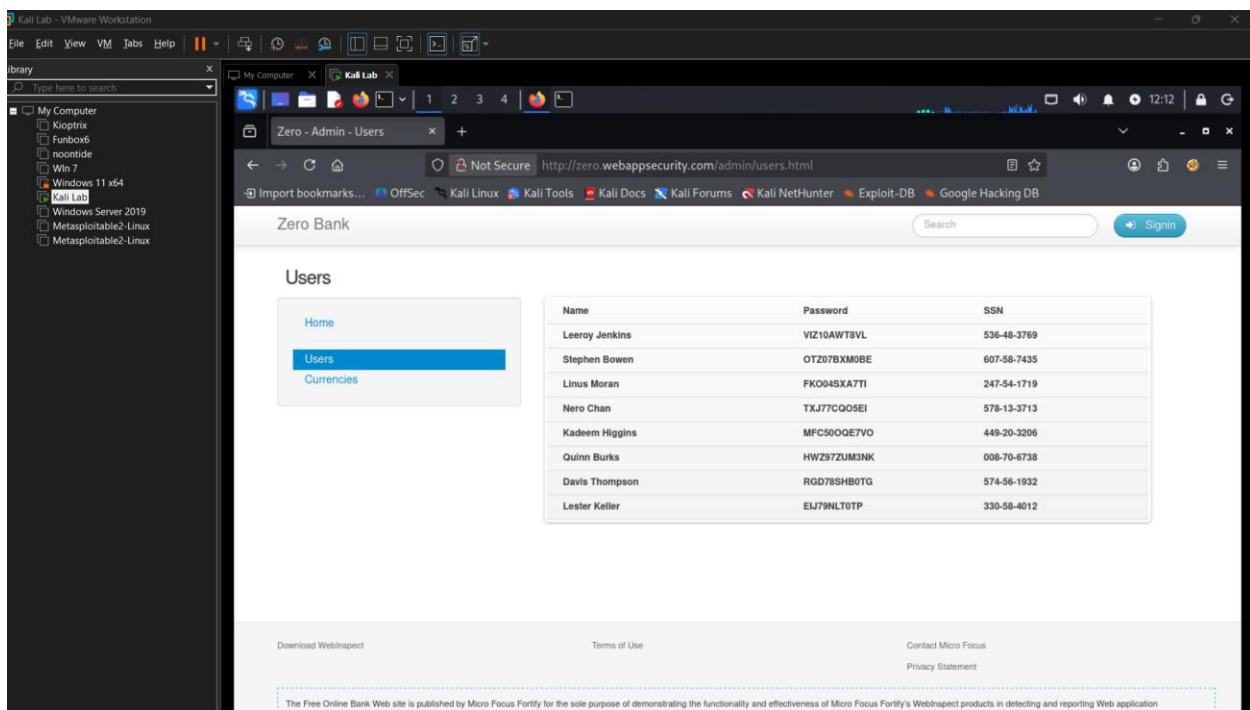
Step 1: Run DIRB to enumerate directories and identify the /admin endpoint.

Command: `dirb http://zero.webappsecurity.com/ /usr/share/wordlists/dirb/common.txt`



Step 2: Navigate directly to the admin users page in the browser without any login.

URL: <http://zero.webappsecurity.com/admin/users.html>



Recommendation

- Immediately restrict all /admin/* paths using role-based access control (RBAC) and require authentication.

- Host administrative interfaces on internal/management networks only, not public-facing.
- Store passwords using strong one-way hashing (bcrypt, Argon2) – never store or display in plaintext.
- Perform periodic configuration audits to ensure no sensitive pages are publicly accessible.

3.2 Vulnerable and Outdated Components

Field	Details
OWASP Category	A06:2021 – Vulnerable and Outdated Components
CVSS v3.1 Score	6.5 – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Severity	MEDIUM
Affected URL / Component	Apache-Coyote/1.1 (Tomcat), OpenSSL 0.9.8e

Description

Nmap scanning revealed the application is running on Apache-Coyote/1.1 (outdated Apache Tomcat) and OpenSSL 0.9.8e – a version released in 2007 that reached end-of-life in 2016. These components have publicly known exploits and no longer receive security patches.

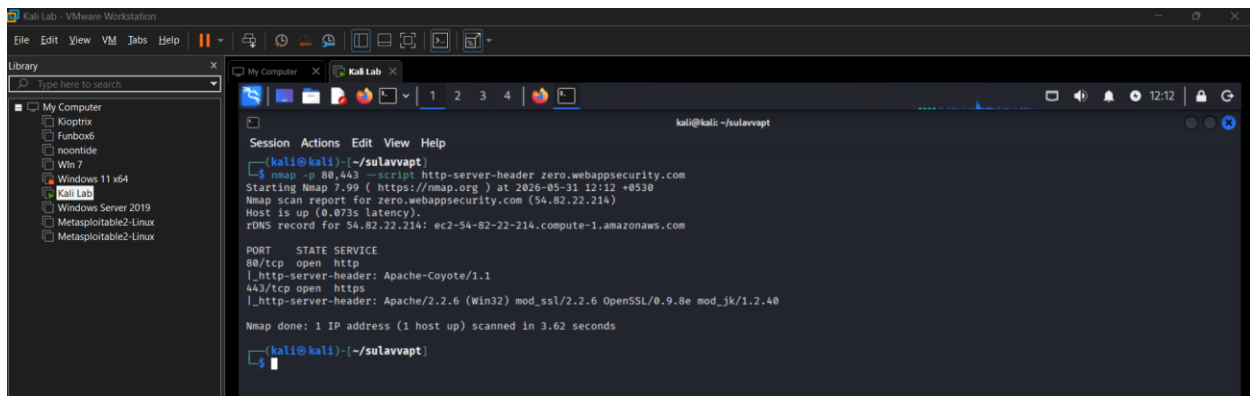
Impact

- OpenSSL 0.9.8e is vulnerable to POODLE, BEAST, and other SSL/TLS attacks.
- Outdated Tomcat versions may be vulnerable to remote code execution (RCE).
- Attackers can fingerprint the server and immediately select targeted exploits from public databases.

Proof of Concept

Run Nmap with the http-server-header script to identify the server software and version:

Command: `nmap -p 80,443 --script http-server-header zero.webappsecurity.com`



Recommendation

- Upgrade Apache Tomcat and OpenSSL to the latest stable supported versions.
- Establish a patch management process for all server components.
- Configure the server to suppress version disclosure in HTTP response headers.
- Subscribe to vendor security advisories and CVE feeds.

4. Conclusion & Next Steps

4.1 Conclusion

The VAPT assessment of <http://zero.webappsecurity.com/> identified two security vulnerabilities. The most critical finding – an unauthenticated admin panel exposing plaintext user credentials and SSNs – represents a severe risk to user privacy and regulatory compliance. The presence of end-of-life server components further increases the attack surface of the application.

The overall security posture of the application is assessed as AT RISK and requires prompt remediation.

4.2 Suggested Remediation Timeline

Finding	Severity	Timeline
Security Misconfiguration – Unprotected Admin Panel (3.1)	Critical	0–7 days
Vulnerable and Outdated Components (3.2)	Medium	30–60 days

4.3 Next Steps

- Immediately restrict access to the admin panel and enforce authentication.
- Upgrade all identified end-of-life server components.
- Perform a re-test after remediation to verify vulnerabilities have been resolved.

- Establish periodic vulnerability assessments and penetration testing.
- Adopt secure development and deployment practices based on OWASP guidelines.